

ASIA PACIFIC INSTITUTE
OF INFORMATION TECHNOLOGY

Cyber Security and Forensics

AICT014-4-2 CSF (VE3)

Week 1

Security Concepts and Models

Learning Outcomes

- At the end of this session you should be able to explain
 - Concepts of Security
 - Common Terms in Security
 - Security Management
 - Risk and Risk Management
 - PAM and SSO
 - Code of Ethics

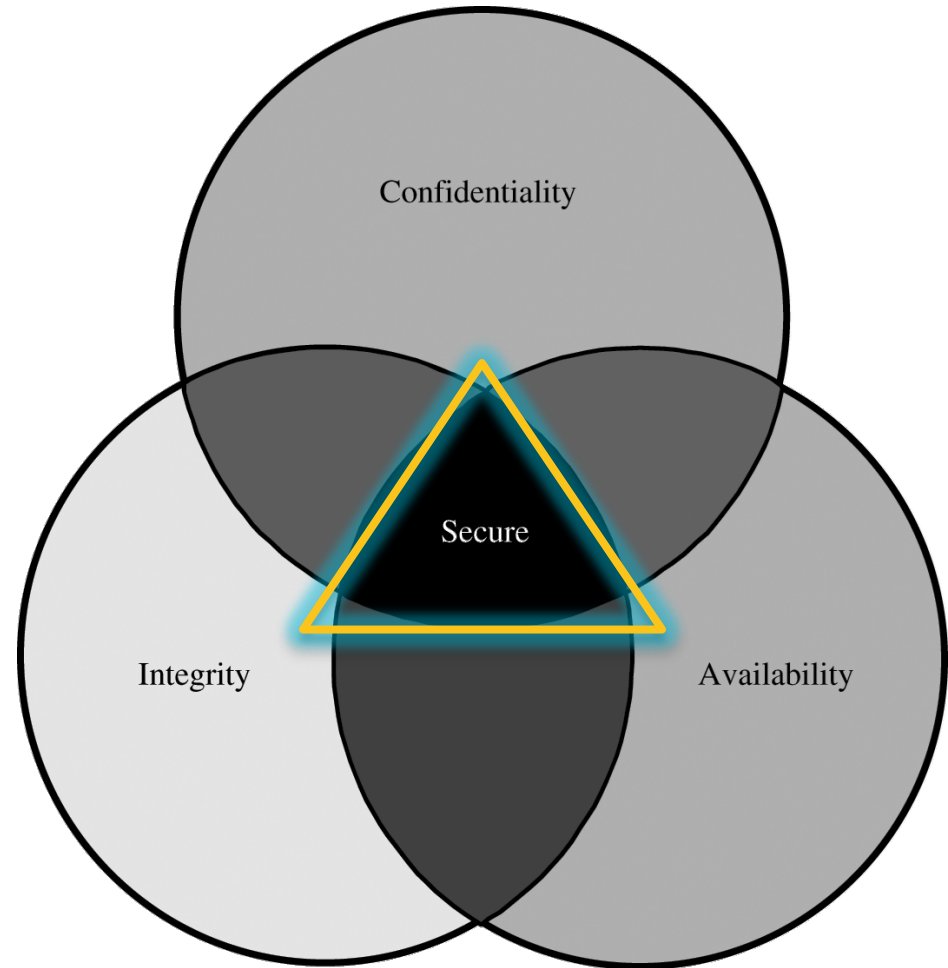
Key Terms You Must Be Able To Use

- If you have mastered this topic, you should be able to use the following terms correctly in your assignments and exams:
- CIA
 - Confidentiality
 - Integrity
 - Availability
- AAA
 - Authentication
 - Authorization
 - Accounting



Security Objectives

- **Confidentiality:**
prevent/detect/deter
improper **disclosure** of
information.
- **Integrity:**
prevent/detect/deter
improper **alteration** of
information.
- **Availability:**
prevent/detect/deter
improper **denial of
access to services.**



CIA and AAA

The three key principles of security control and management



A security concept for a centralized platform that performs three separate identity-based tasks.



CIA Triad

Principle	Description
Confidentiality	Keeping information and communications private and protected from unauthorized access. • trade and military secrets; personnel, health, and tax records. • Controlled via encryption, access control, and steganography.
Integrity	Keeping organizational information accurate, free of errors, and free from unauthorized modification. • Includes modification information stored on network servers. • Controlled via hashing, digital signatures, certificates, and change control.
Availability	Ensuring that computer systems operate continuously and that authorized persons can access the data they need. • Includes ensuring that vital data are both captured and distributed • Controlled via redundancy, fault tolerance, and patching.

AAA Defined



Authentication: the method of identifying users, including login and password dialog, challenge and response, messaging support, and, depending on the security protocol selected, possibly encryption.



Authorization: the method for access control, including one-time authorization or authorization for each service, per-user account list and profile, user groups, and protocols



Accounting: the method for collecting and sending information used for auditing and reporting, such as user identities, start and stop times, executed commands, number of packets, and number of bytes.

Common Terms



Accounting: The process of tracking and recording system activities and resource access.



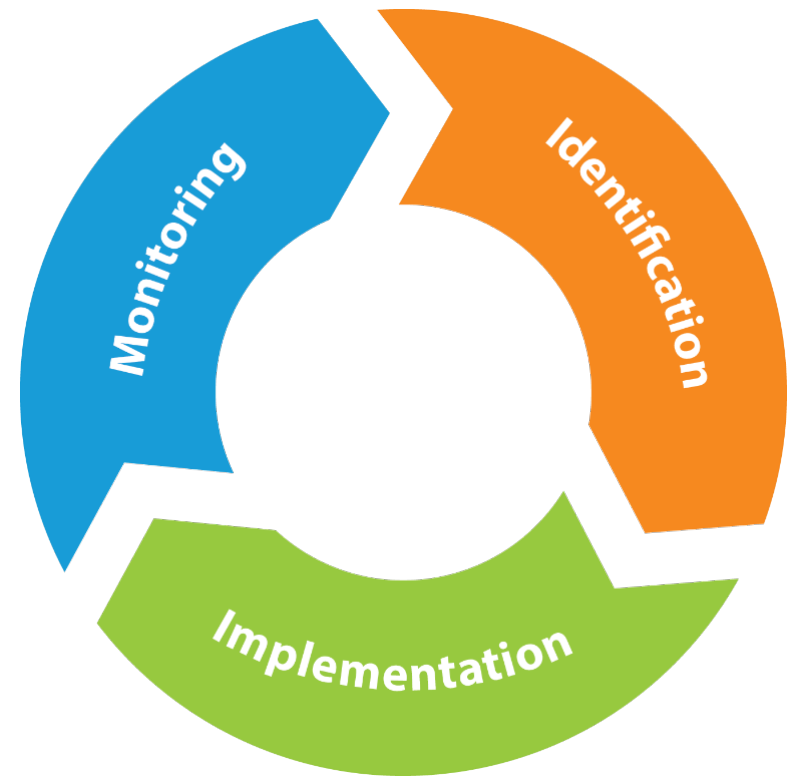
Auditing: The portion of accounting that entails security professionals examining logs of what was recorded.



Accountability: Determining who to hold responsible for a particular activity or event.

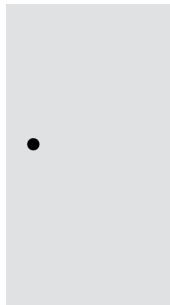
Security Management Process

- Identify security controls: Detecting problems and determining how best to protect the system.
- Implement security controls: Installing control mechanisms to prevent problems in a system.
- Monitoring security controls: Involves detecting and solving any security issues that arise after security controls are implemented.



Controls

- Countermeasures put in place to avoid, mitigate, or counteract security risks due to threats and attacks.
 - Solutions and activities for meeting information security objectives.
 - Safeguards and countermeasures, physical or logical.



**Prevention
Control**



Detection Control

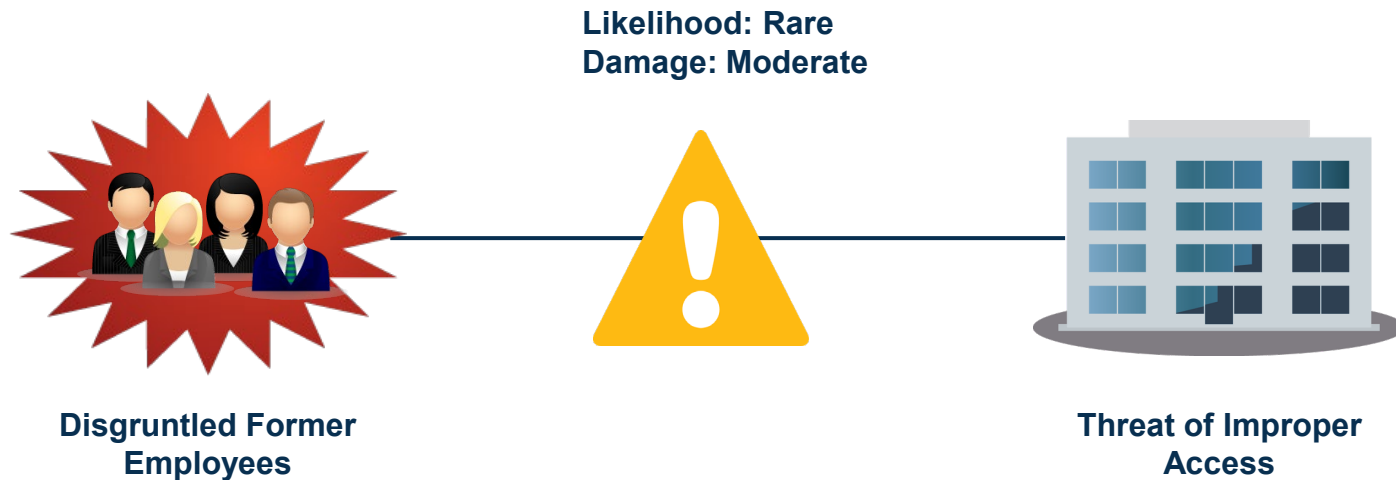


**Correction
Control**

Risk

A concept that indicates exposure to the chance of damage or loss and signifies the likelihood of a hazard or dangerous threat.

- IT risk is associated with system, power, network, and physical losses.
 - Can also affect people, practices, and processes.
- Data in all forms must be protected.
- Organizations must take risk into account when information security is designed and implemented.



Vulnerabilities

Any condition that leaves a device open to harm.

- Improperly configured or installed hardware or software
- Delays in applying and testing software and firmware patches
- Untested software or firmware patches
- Bugs in software or OSs
- Misusing software or communication protocols
- Poorly designed networks
- Poor physical security
- Insecure passwords
- Design flaws in software or OSs
- Unchecked user input

Operations Vulnerabilities

Untrained users

- Human element is largest target.
- Users not equipped to spot social engineering or practice good computer security habits.

Lack of planning for critical business processes

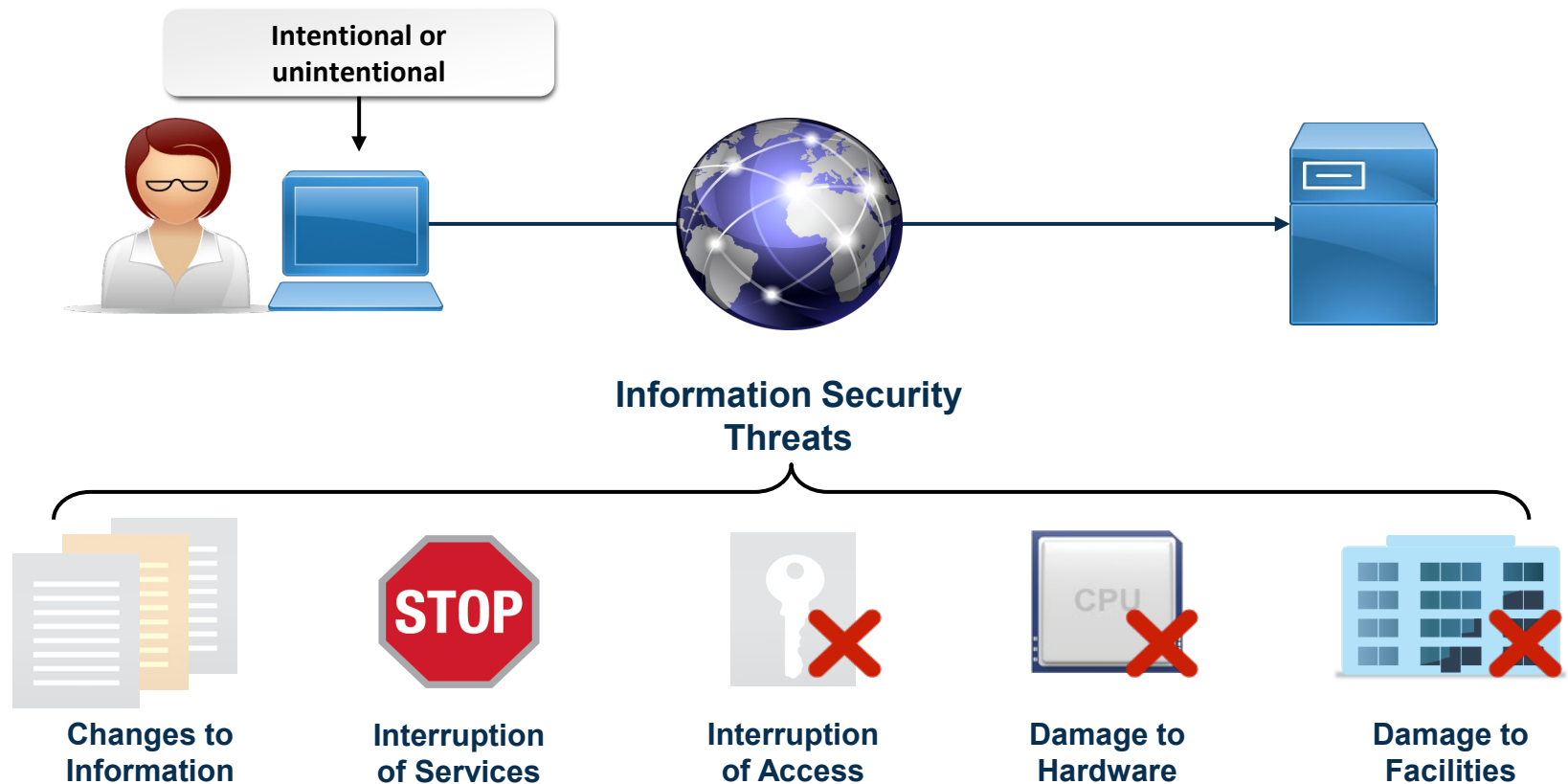
- Without EOL processes, obsolete systems may be vulnerable.
- Lack of vendor support makes fixing issues more difficult.
- Embedded systems may be difficult to understand.

System sprawl

- Difficult for limited personnel to oversee large number of systems.
- Inability to manage these systems can lead to compromise.
- Undocumented assets are difficult to manage consistently.

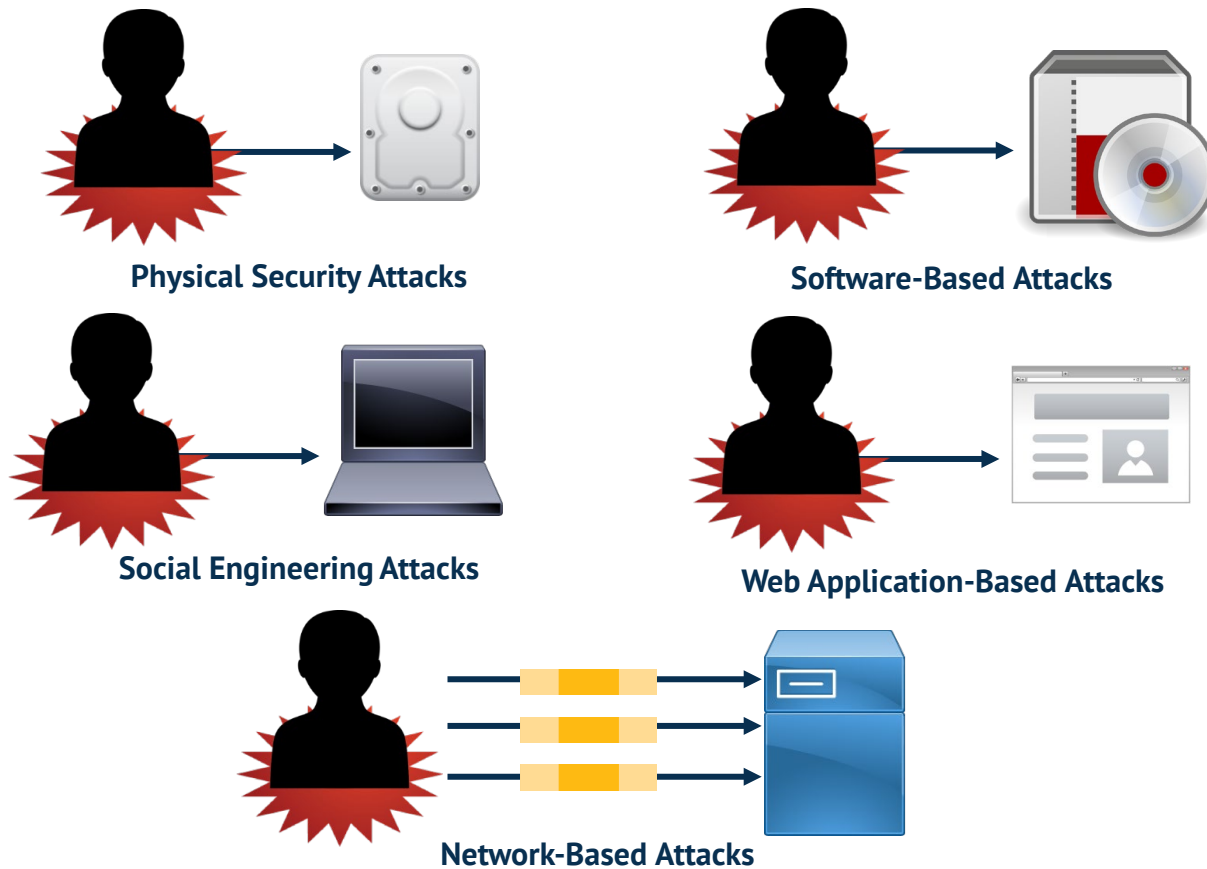
Threats

Any event or action that could potentially cause damage to an asset.



Attacks

A technique used to exploit a vulnerability in an application or physical computer system without the authorization to do so.



Risk Management



Risk Management refers to the practice of identifying potential **risks** in advance, analyzing them and taking precautionary steps to reduce the **risk**

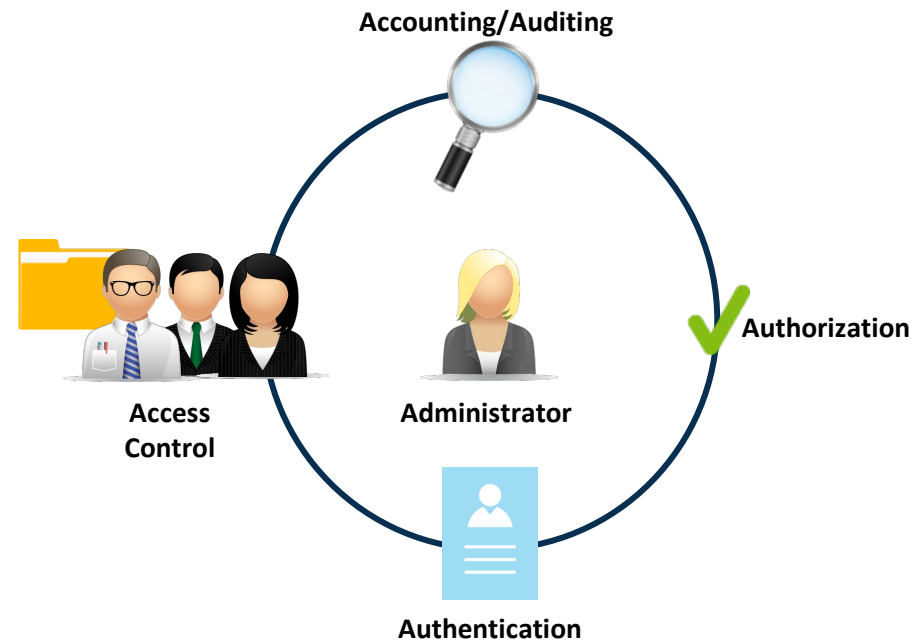


Risk can be determined as a function of the **probability** of a **threat** exploiting a **vulnerability**, and the **probable value** of damage to assets

$$\text{Risk} = f(\text{Threat}, \text{Vulnerability}, \text{Value})$$

PAM and SSO

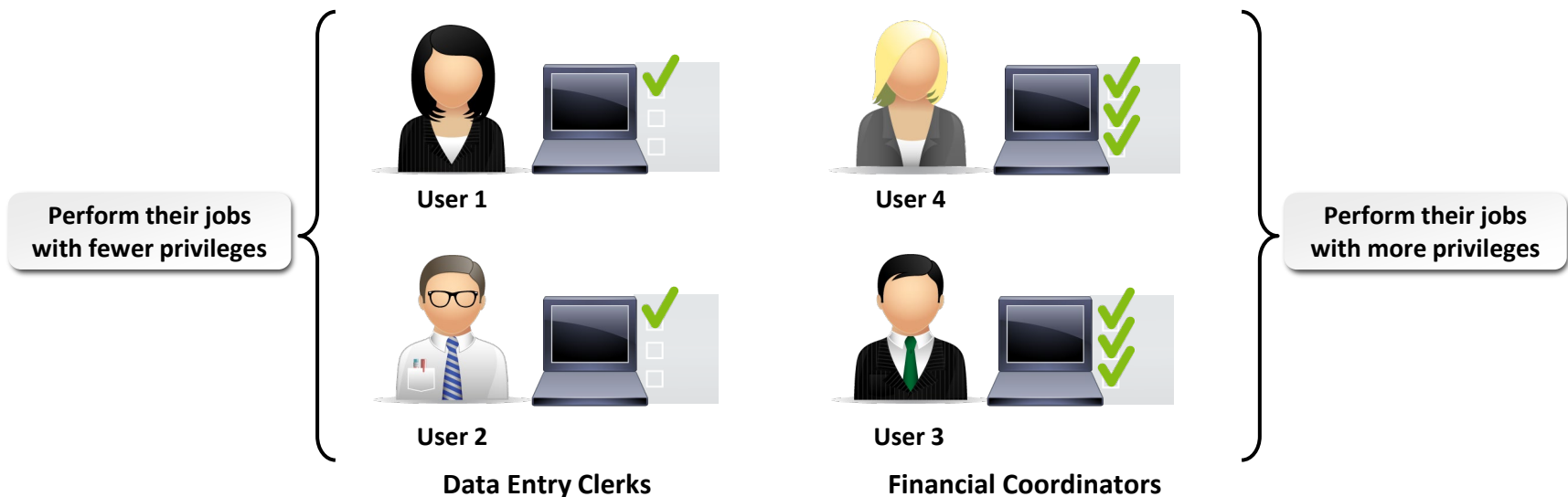
- Privilege Access Management: The use of authentication and authorization mechanisms to provide centralized or decentralized administration of user and group access control.
- Single Sign-On: An aspect of privilege management that provides users with one-time authentication to multiple resources, servers, or sites.



Access Control $\Leftrightarrow$ Availability

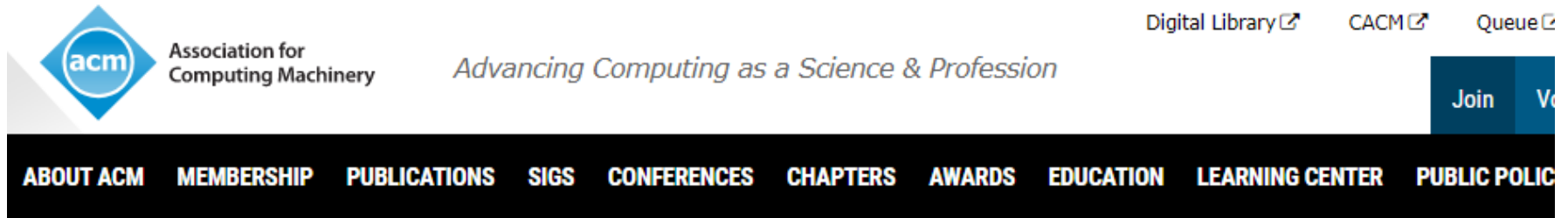
Principle of Least Privilege

- Users and software should have the minimal level of access that is necessary for them to perform the duties required of them.
 - Applies to access to facilities, computer hardware, software, and information.
 - Assign only the level of access required to perform the necessary tasks.



Code of Ethics

- www.acm.org/about/code-of-ethics



Home > Code Of Ethics

ACM Code of Ethics and Professional Conduct

Code of Ethics



The actions of computing professionals change the world.



To act responsibly, they should reflect upon the wider impacts of their work, consistently supporting the public good.



The ACM Code of Ethics and Professional Conduct expresses the conscience of the profession.

Code of Ethics



The Code is concerned with how fundamental ethical principles apply to a computing professional's conduct.



The Code is not an algorithm for solving ethical problems; rather it serves as **a basis for ethical decision-making**.



When thinking through an issue, questions can best be answered by thoughtful consideration of the fundamental ethical principles



Multiple principles should be considered, and different principles will have different relevance to the issue.

ACM Code of Ethics and Professional Conduct

Affirming our obligation to use our skills to benefit society

- General Ethical Principles
- Professional Responsibilities
- Professional Leadership Principles
- Compliance with the Code
- Case Studies
- Using the Code

Further Reading

- <https://www.acm.org/code-of-ethics/case-studies>



Case Study: Malware

Rogue Services touts its web hosting as “cheap, guaranteed uptime, no matter what.” While some of Rogue’s clients are independent web-based retailers, most are focused on malware and spam, which leverage Rogue for continuous delivery. Corrupted advertisements often link to code hosted on Rogue to exploit browser vulnerabilities to infect machines with ransomware. Rogue refuses to intervene with these services despite repeated requests.



Case Study: Automated Active Response Weaponry

Q Industries is an international defense contractor specializing in autonomous vehicles. As an early pioneer in passive systems, such as bomb-defusing robots and crowd-monitoring drones, Q established itself as a vendor of choice for military and law enforcement applications. Q’s products have been deployed in a variety of settings, including conflict zones and nonviolent protests. Recently, however, Q has begun to experiment with automated active responses.



Case Study: Malicious Inputs to Content Filters

The U.S. Children’s Internet Protection Act (CIPA) mandates that public schools and libraries employ mechanisms to block inappropriate matter on the grounds that it is deemed harmful to minors. Blocker Plus is an automated Internet content filter designed to help these institutions comply with CIPA’s requirements. During a review session, the development team reviewed a number of complaints about content being blocked inappropriately.

Summary of Main Teaching Points

Concepts of
Security

Common
Terms in
Security

Security
Management

Risk and Risk
Management

PAM and SSO

Code of Ethics



See you in the next lecture!

THANK YOU